

This website utilizes technologies such as cookies to enable essential site functionality, as well as for analytics, personalization, and targeted advertising. [Privacy Policy](#).

Accept

Deny Non-Essential

Manage Preferences

Commands in this context are often standalone strings that are interpreted by a downstream component and cause specific responses. This type of attack is possible when untrusted values are used to build these command strings. Weaknesses in input validation or command construction can enable the attack and lead to successful exploitation.

▼ **Likelihood Of Attack**

Medium

▼ **Typical Severity**

High

▼ **Relationships**

	Nature	Type	ID	Name
	ParentOf		40	Manipulating Writeable Terminal Devices
	ParentOf		66	SQL Injection
	ParentOf		88	OS Command Injection
	ParentOf		136	LDAP Injection
	ParentOf		183	IMAP/SMTP Command Injection
	ParentOf		250	XML Injection
	ParentOf		676	NoSQL Injection

	View Name	Top Level Categories
	Domains of Attack	Software
	Mechanisms of Attack	Inject Unexpected Items

▼ **Prerequisites**

The target application must accept input from the user and then use this input in the construction of commands to be executed. In virtually all cases, this is some form of string input that is concatenated to a constant string defined by the application to form the full command to be executed.

▼ **Consequences**

	Scope	Impact	Likelihood
	Confidentiality Integrity Availability	Execute Unauthorized Commands	

▼ **Mitigations**

All user-controllable input should be validated and filtered for potentially unwanted characters. Using an allowlist for input is desired, but if use of a denylist approach is necessary, then focusing on command related terms and delimiters is necessary.

Input should be encoded prior to use in commands to make sure command related characters are not treated as part of the command. For example, quotation

▼ Taxonomy Mappings

Relevant to the OWASP taxonomy mapping

Entry Name
Command Injection

▼ References

[REF-615] "OWASP Web Security Testing Guide". Testing for Command Injection. The Open Web Application Security Project (OWASP). <https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Input_Validation_Testing/12-Testing_for_Command_Injection.html>.

► Content History

Page Last Updated or Reviewed: July 31, 2018